Website launch security: turn the reel checklist into tested controls

Researched 2026-10-12.

What was captured

Muse reconstructs a nineteen-point spoken checklist covering injection, access control, authentication, secrets, headers, dependencies and operational safeguards. The creator's "every single time" success claim has no supplied study or test artifacts. The comment/DM funnel is unnecessary to begin a scoped review.

Current authoritative references

The OWASP Top 10 project (https://owasp.org/www-project-top-ten/) currently identifies 2025 as its released version. It is an awareness document. ASVS (https://owasp.org/www-project-application-security-verification-standard/) supplies more specific verification requirements. Choose applicable controls rather than pretending a short reel replaces a threat model or complete assessment.

Convert each checklist entry into evidence

Area	Example verification	Evidence to keep
Object access	User A cannot read/change user B's fixture object	Request, expected denial, regression test
Injection	Query parameters remain bound data	Code location and malicious-input test
XSS	Untrusted content cannot become executable markup	Browser test of the output boundary
Sessions/CSRF	Cross-origin state changes fail under the app's auth model	Test request and observed result
Secrets/dependencies	No shipped key; dependency findings reviewed	Scan result and remediation record
Rate limits/recovery	Abuse path is bounded; backup restores	Load cap test and restore exercise

These are proposed test designs, not claims that they passed on any app. Exercise only systems you own or are authorized to test, using fixture accounts/data.

AI-specific additions

For an LLM-enabled app, examine prompt injection, tool permissions, data exfiltration and output handling using the OWASP LLM guidance (https://genai.owasp.org/llm-top-10/). An assistant-generated "secure"

verdict is not a substitute for demonstrated controls. Keep server-enforced access checks independent of the model.

Local learning option

OWASP Juice Shop (https://owasp.org/www-project-juice-shop/) is an intentionally vulnerable training app. Use its own current setup guide in an isolated local environment; no installation line is guessed here. Keep a vulnerable training service off public interfaces.

Proposed project

Build a small launch-review workbook: control ID, scope, test, result, severity, fix, retest and evidence link. Start with five controls for one real fixture app and export a Markdown/PDF report. Treat unchecked rows as unverified, never green by default. Merge this source with Kiln's earlier launch/security checklists, keeping the original detailed checks available.

Reusable project prompt

```
Build Evidence-based launch workbook. Applicable controls with actual test evidence, remediation and retest status. Read the linked official docs first. Use fixture data; keep credentials outside source control. Deliver tests, setup instructions, an evidence/limitations note and a small reproducible example. Do not claim a measurement you did not run. Milestones: Select five scoped controls; Define fixture-based tests; Record evidence and fixes; Export a reviewable report.
```

Delivery and next step

The linked current sources were retrieved for this guide; the original dossier and its extraction caveats are retained in Sources. The guide and printable PDF are research deliverables. The proposed project has not been built. Start with the first milestone and verify its acceptance criteria before expanding the scope.

Original sources

- https://www.instagram.com/reel/DeM46Iay29L/